

Kötü Amaçlı Yazılım Analizi ve Tespiti Üzerine Brifing Notu

Yönetici Özeti

Bu brifing, kötü amaçlı yazılım analizinin temel ilkelerini, saldırganlar tarafından kullanılan yaygın kaçınma tekniklerini ve modern siber saldırılarda kullanılan yerleşik sistem araçlarını (Living-Off-the-Land) özetlemektedir. Temel çıkarımlar şunlardır: Kötü amaçlı yazılım analizi, bir yazılımın amacını ve işlevselliğini anlamak için statik (çalıştırmadan) ve dinamik (kontrollü bir ortamda çalıştırarak) olmak üzere iki ana kategoriye ayrılır. Analistler, bu süreçte kazara bulaşmayı önlemek için yalıtılmış sanal makineler kullanmak ve örnekleri parola korumalı arşivlerde tutmak gibi katı güvenlik önlemlerine uymalıdır. Saldırganlar, paketleme, gizleme ve sanal makine veya kullanıcı etkinliğini tespit etmeye yönelik sandbox'tan kaçınma gibi analiz karşıtı teknikler kullanarak tespit edilmekten kaçınmaya çalışırlar. Ek olarak, "Living-Off-the-Land" (LOL) saldırıları giderek daha yaygın hale gelmektedir. Bu saldırılarda, PowerShell, WMIC ve Certutil gibi meşru ve güvenilir sistem araçları, kötü amaçlı eylemleri gerçekleştirmek için kullanılır. Bu yaklaşım, saldırganların geleneksel güvenlik kontrollerini atlamasına ve normal yönetim faaliyetleri arasında gizlenmesine olanak tanır. Etkili savunma, katmanlı güvenlik kontrolleri, uygulama denetimi, en az ayrıcalık ilkesi ve şüpheli komut satırı etkinliklerinin proaktif olarak izlenmesini gerektirir. Son olarak, kötü amaçlı yazılımların Reklam Yazılımı (Adware), Fidyeye Yazılımı (Ransomware) ve Veri Hırsız (Data Stealer) gibi farklı kategorilere ayrılması, tehditleri hızlı bir şekilde tanımlama ve müdahale etme yeteneğini geliştirir.

1. Kötü Amaçlı Yazılım Analizinin Temelleri

Kötü amaçlı yazılım (malware) terimi, **MAL**icious soft **WARE** (kötü niyetli yazılım) kelimelerinden türetilmiştir. Kötü amaçlı yazılım analizi, bir yazılımın ne yapmaya çalıştığını anlamak için bir bulmacayı çözmeye benzer. Bu süreçte analistler, bir PE (Portable Executable) dosyası, kötü amaçlı bir belge veya bir ağ paket yakalaması (pcap) gibi farklı unsurları inceler.

Güvenlik Önlemleri

Kötü amaçlı yazılımlar dikkatsizce ele alındığında bir silah kadar tehlikeli olabilir. Analize başlamadan önce aşağıdaki güvenlik önlemlerine her zaman uyulmalıdır:

- Asla tek amacı kötü amaçlı yazılım analizi olmayan bir makinede analiz yapmayın.
- Kötü amaçlı yazılım örnekleri analiz edilmediğinde veya taşınmadığında, kazara çalıştırılmalarını önlemek için daima parola korumalı zip/rar gibi arşivlerde saklayın.
- Kötü amaçlı yazılımı bu parola korumalı arşivden yalnızca yalıtılmış ortamın içinde ve sadece analiz sırasında çıkarın.
- Kötü amaçlı yazılım analizi için özel olarak, işiniz bittiğinde temiz bir duruma geri döndürülebilen yalıtılmış bir sanal makine (VM) oluşturun.
- Tüm internet bağlantılarının kapalı olduğundan veya en azından izlendiğinden emin olun.
- Analiz bittikten sonra, bir önceki çalıştırmadan kalan artıkların bir sonraki analizi bozmamasını sağlamak için sanal makineyi temiz durumuna geri döndürün.

Temel Analiz Yöntemleri

Kötü amaçlı yazılım analizi için kullanılan teknikler genel olarak iki ana kategoriye ayrılır: Statik Analiz ve Dinamik Analiz.

Statik Analiz

Kötü amaçlı bir yazılımın **çalıştırılmadan** incelenmesine Statik Analiz denir. Bu yaklaşımda, PE dosyasının veya kötü amaçlı bir belgenin özellikleri, çalıştırılmadan analiz edilir. Statik analiz örnekleri şunlardır:

- Yazılım içindeki metin dizelerini (strings) kontrol etmek.
- Farklı bölümlerle ilgili bilgi için PE başlığını incelemek.
- Kodu bir ayrıştırıcı (disassembler) kullanarak incelemek. Ancak, saldırganlar genellikle kodlarını gizlemek (obfuscation) veya paketlemek (packing) gibi teknikler kullanarak statik analizi zorlaştırırlar. Bu durumlarda dinamik analiz devreye girer.

Dinamik Analiz

Kötü amaçlı yazılımlar, amaçlarını gerçekleştirmek için çalışmak zorundadır ve bu durum, ne kadar gizleme tekniği kullanılırsa kullanılsın, çalıştıkları anda onları tespit için bir hedef haline getirir. Dinamik analiz, kötü amaçlı yazılımın kontrollü bir ortamda çalıştırılarak davranışlarının gözlemlenmesini içerir. Bu yöntem, statik analizin yetersiz kaldığı durumlarda oldukça etkilidir.

- **Uygulama:** Kötü amaçlı yazılım, manuel olarak veya otomatik sandbox'lar aracılığıyla, aktivitesini izlemek için kurulmuş araçlarla donatılmış bir sanal makinede çalıştırılır.
- **Avantajı:** Ortam kontrol altında olduğundan, meşru kullanıcı veya Windows servislerinden kaynaklanan gürültü en aza indirilir. Bu sayede gözlemlenen her aktivite, doğrudan kötü amaçlı yazılımın eylemlerine işaret eder.
- **Zorluğu:** Kötü amaçlı yazılımlar, genellikle **çalıştıkları ortamı tespit ederek** dinamik analizi atlatmaya çalışır. Kontrollü bir ortamda çalıştığını anlarsa, zararsız bir kod yolunu takip ederek gerçek amacını gizleyebilir.

İleri Düzey Kötü Amaçlı Yazılım Analizi

Temel statik ve dinamik analizden kaçan kötü amaçlı yazılımlar için ileri düzey teknikler kullanılır. Bu teknikler, ayrıştırıcılar (disassemblers) ve hata ayıklayıcılar (debuggers) gibi araçları içerir. Ayrıştırıcılar, yazılımın ikili kodunu assembly diline çevirerek analistin talimatları statik olarak incelemesine olanak tanır. Hata ayıklayıcılar ise çalışan bir programa bağlanarak analistin talimatları izlemesine, programı belirli noktalarda durdurup çalıştırmasına ve sistemin bellek ve CPU durumunu gözlemlemesine olanak tanır.

Statik Analiz Teknikleri

Dosya Türünü İnceleme Saldırganlar, kullanıcıları yanıltmak için aldatıcı dosya uzantıları kullanabilir. Dosyanın gerçek türünü belirlemek için Linux'taki file komutu gibi araçlar kullanılabilir. **Dizeleri (Strings) İnceleme** Bir dosyadaki okunabilir metin dizelerini listelemek için kullanılan strings komutu, dosyanın işlevselliği hakkında önemli ipuçları (IP adresleri, URL'ler, dosya adları vb.) sağlayabilir. **Karma Değerlerini (Hashes) Hesaplama** Dosya karması (hash), bir dosyayı benzersiz bir şekilde tanımlayan sabit boyutlu bir değerdir. Bu, kötü amaçlı yazılımlar için bir kimlik belirteci olarak kullanılır ve analistler arasında bilgi paylaşımı veya çevrimiçi araştırma için kritik öneme sahiptir. Yaygın olarak md5sum,

sha1sum ve sha256sum kullanılır. Bir dosyadaki tek bir bit değışikliğı bile karma değerini tamamen değıştirecektir.**PE (Portable Executable) Başlığı** PE başlığı, bir yürütülebilir dosya hakkında zengin meta veriler içerir. Analiz için hayati bilgiler sunar.

- **Imports/Exports:** PE dosyaları, işletim sisteminin sağladığı mevcut kodları yeniden kullanır. "Import"lar, PE dosyasının dışarıdan aldığı fonksiyonlardır ve dosyanın ne yapacağına dair önemli ipuçları verir. Örneğın, InternetOpen fonksiyonunu import eden bir dosyanın internet ile iletişim kuracağı, URLDownloadToFile fonksiyonunu import edenin ise internetten bir dosya indireceğı anlaşılr. "Export"lar ise genellikle DLL dosyalarıyla ilişkilidir ve diğır ikili dosyaların kullanabilmesi için dışarıya açılan fonksiyonlardır.
- **Bölümler (Sections):** Bir PE dosyası farklı amaçlara hizmet eden bölümlere ayrılmıştır. En yaygın bölümler şunlardır:
- **.text:** Genellikle PE dosyası çalıştığında yürütölen CPU talimatlarını içerir. Yürütölebilir olarak işaretlenmiştir.
- **.data:** Global değışkenleri ve diğır global verileri içerir.
- **.rsrc:** Resimler, ikonlar gibi PE dosyasının kullandığı kaynakları içerir.

2. Analiz Karşıtı Teknikler

Saldırganlar, analistlerin işini zorlaştırmak için çeşitli teknikler kullanır.

Paketleme ve Gizleme (Packing and Obfuscation)

Paketleyiciler (packers), kötü amaçlı yazılımın içeriğini gizler, sıkıştırır veya şifreler. Bu teknikler, özellikle strings komutu gibi statik analiz araçlarının önemli bilgileri bulmasını zorlaştırır.

Sandbox'tan Kaçınma (Sandbox Evasion)

Kötü amaçlı yazılımlar, otomatik analiz sistemlerinden (sandbox) kaçmak için geliştirilmiş teknikler içerir:

- **Uzun Uyku Çağrılar (Long sleep calls):** Sandbox'ların sınırlı bir süre çalıştığını bilen saldırganlar, yazılımın uzun bir süre hiçbir aktivite göstermemesini programlar. Bu, sandbox'ın zaman aşımına uğramasını hedefler.
- **Kullanıcı Etkinliği Tespiti:** Bazı yazılımlar, kötü amaçlı faaliyetlerini gerçekleştirmeden önce fare hareketi veya klavye girişı gibi kullanıcı etkinliklerini bekler. Bu, bir sandbox'ta insan kullanıcının olmayacağı varsayımına dayanır.
- **Kullanıcı Etkinliği Ayak İzleri:** Kötü amaçlı yazılım, MS Office geçmişı veya internet tarama geçmişı gibi kullanıcı dosyalarını kontrol eder. Eğer çok az veya hiç etkinlik bulamazsa, makineyi bir sandbox olarak kabul edip çalışmayı durdurur.
- **Sanal Makine Tespiti:** Sandbox'lar sanal makinelerde çalışır. VMWare veya Virtualbox gibi platformlarda çalışan sanal makineler, kötü amaçlı yazılımlar tarafından tespit edilebilecek belirli sürücüler gibi izler bırakır. Sanal makine tespit edildiğinde yazılım sonlandırılır.

3. "Living Off the Land" (LOL) Saldırıları

Saldırganlar her zaman özel kötü amaçlı yazılımlara güvenmezler. Bunun yerine, hedef makinede zaten mevcut olan güvenilir sistem araçlarını kullanabilirler. Bu teknik, yerleşik araçların zaten güvenilir olması, yaygın olarak bulunması ve varsayılan kontroller tarafından

genellikle izin verilmesi nedeniyle tercih edilir. Bu sayede kötü amaçlı faaliyetler normal operasyonlar arasında gizlenebilir.

Yaygın Olarak Kötüye Kullanılan Araçlar ve Teknikler

Araç,Kötüye Kullanım Amacı

PowerShell,"Bellek içi betik çalıştırma, uzaktan dosya indirme ve otomasyon."

WMIC / WMI,Komutları yerel veya uzak ana bilgisayarlarda çalıştırma ve sistem durumunu sorgulama.

Certutil,Dosyaları indirme ve base64 ile kodlanmış yükleri çözme.

Mshta,HTA içeriğini veya bir belge/bağlantı tarafından sunulan satır içi betiği çalıştırma.

Rundll32,DLL export'larını çağırma veya URL işleyicilerini tetikleme.

Zamanlanmış Görevler (schtasks),Kalıcılık için oturum açılışında veya belirli bir zamanlamayla kod çalıştırma.

Bu yöntemler yalnızca Windows ile sınırlı değildir; Windows için **LOLBAS** ve Unix/Linux için **GTFOBins** gibi kamuya açık koleksiyonlar, her iki platform için de yaygın kalıpları belgelemektedir.

Savunma ve Azaltma Stratejileri

- Uç nokta, ağ ve kimlik korumalarını birleştiren katmanlı savunma kontrolleri uygulayın.
- Hangi betiklerin ve yürütülebilir dosyaların çalıştırılmasına izin verildiğini tanımlamak için AppLocker gibi uygulama kontrol politikaları uygulayın.
- Yalnızca yöneticilerin sistem yönetim araçlarına erişebilmesini sağlayarak en az ayrıcalık ilkesini uygulayın.
- Kötü amaçlı faaliyetlerle bilinen alan adlarına ve IP'lere bağlantıları engellemek için ağ kuralları ve DNS filtreleri yapılandırın.
- Risk altındaki sistemleri izole etme ve açığa çıkan kimlik bilgilerini iptal etme adımlarını özetleyen net müdahale planları oluşturun.

Araç Bazında Ayrıntılı Analiz

PowerShell

- **Açıklama:** Windows sistemlerinde yönetim ve otomasyon için kullanılan bir betik motorudur.
- **Saldırgan Kullanımı:** Betikleri doğrudan bellekte çalıştırabildiği, diskte iz bırakmadığı ve bazı yürütme politikalarını atlayabildiği için saldırganlar tarafından tercih edilir. Yükleri indirmek, bilgi toplamak ve sistem ayarlarını gizlice değiştirmek için kullanılır.
- **LOL Örnekleri:** IEX (DownloadString) deseni, uzaktaki bir betiği alıp doğrudan bellekte çalıştırır. -EncodedCommand bayrağı ise yükü base64 formatında gizleyerek basit log filtrelerini atlatır.
- **Tespit Örneği:** (CommandLine="powershell/IEX*" OR CommandLine="powershell-EncodedCommand*" OR CommandLine="Invoke-WebRequest")

WMIC

- **Açıklama:** Yöneticilerin yerel veya uzak Windows sistemlerini yönetmesine olanak tanıyan bir komut satırı aracıdır.
- **Saldırgan Kullanımı:** Harici ikili dosyalar kullanmadan uzaktan komut çalıştırmak, sistem bilgisi toplamak veya kalıcılık sağlamak için kullanılır. Yönetici davranışıyla uyumlu olduğu için fark edilmesi zordur.
- **LOL Örnekleri:** Uzak bir ana bilgisayarda yeni bir işlem (örneğin, PowerShell) başlatmak veya çalışan işlemler hakkında bilgi toplamak için kullanılır.
- **Tespit Örneği:** (CommandLine="\\wmic.exe process call create*" OR CommandLine="wmic /node: process call create*")

Certutil

- **Açıklama:** Sertifikaları yönetmek ve verileri kodlamak/kod çözmek için kullanılan bir Microsoft aracıdır.
- **Saldırgan Kullanımı:** Microsoft tarafından imzalı olduğu için güvenilirdir. -urlcache bayrağı ile dosya indirmek ve base64 ile kodlanmış yükleri çözerek metin dosyalarını ikili dosyalara dönüştürmek için kötüye kullanılır.
- **LOL Örnekleri:** -urlcache -split -f bayrakları ile uzaktaki bir dosyayı diske indirir. -decode ile base64 metnini yürütülebilir bir dosyaya dönüştürür.
- **Tespit Örneği:** (Image="\\certutil.exe" AND (CommandLine="-urlcache * -f " OR CommandLine="-decode *"))

MSHTA

- **Açıklama:** VBScript veya JavaScript kodu içerebilen HTML Uygulama (HTA) dosyalarını çalıştırır.
- **Saldırgan Kullanımı:** Uzak bir sunucudan HTA içeriğini yükleyip çalıştırarak veya satır içi JavaScript URI'leri kullanarak doğrudan sistem komutlarını tetikler.
- **LOL Örnekleri:** Uzak bir URL'den HTA dosyası çalıştırma veya javascript: protokolünü kullanarak WScript.Shell nesnesi oluşturup PowerShell'i tetikleme.
- **Tespit Örneği:** Image="\\mshta.exe" (CommandLine="http://" OR CommandLine="javascript:" OR CommandLine="*.hta")

Rundll32

- **Açıklama:** DLL dosyalarından belirli export edilmiş fonksiyonları yürütür.
- **Saldırgan Kullanımı:** Saldırganlar, özel olarak hazırlanmış DLL'lerin fonksiyonlarını çağırarak kodlarını çalıştırır. url.dll'in FileProtocolHandler fonksiyonu uzaktan içerik işlemek için kullanılabilir.
- **Tespit Örneği:** Image="\\rundll32.exe" (CommandLine="url.dll,FileProtocolHandler" OR CommandLine="\\Users\\Public\\" OR CommandLine="\\Windows\\Temp*")

Zamanlanmış Görevler (schtasks)

- **Açıklama:** Programların veya betiklerin belirli zamanlarda veya olaylara bağlı olarak çalışmasını sağlayan yerleşik bir Windows otomasyon aracıdır.
- **Saldırgan Kullanımı:** Yeniden başlatmalarda kalıcılık sağlamak, oturum açılışında kod çalıştırmak veya yükleri yeniden başlatmak için kullanılır. Saldırganlar genellikle WindowsUpdate gibi zararsız görünen görev adları seçerler.

- **LOL Örnekleri:** Oturum açılışında PowerShell ile uzaktan bir betik indiren bir görev oluşturma veya belirli bir görevi anında çalıştırmak için /Run komutunu kullanma.
- **Tespit Örneği:** (EventCode=4698 OR CommandLine="schtasks /Create*" OR CommandLine="schtasks /Run*")

4. Kötü Amaçlı Yazılım Sınıflandırması

Kötü amaçlı yazılım türlerini ve davranışlarını bilmek, analistlerin tehditleri hızla tespit etmesine yardımcı olur.

Kötü Amaçlı Yazılım Kategorileri

Kategori, Ana Amaç, Tipik Davranış, Gerçek Dünya Örneği

Reklam Yazılımı (Adware), İstenmeyen reklamlar gösterme, İstenmeyen reklamlar gösterir, Fireball

Casus Yazılım (Spyware), Gizlice bilgi toplama, "Tarama geçmişini izler, tuş vuruşlarını kaydeder, verileri yakalar", Hermit

Fidye Yazılımı (Ransomware), Dosyaları veya sistemleri kilitleyerek para sızdırma, "Verileri şifreler, fidye notu gösterir", WannaCry

Silici (Wiper), Verileri veya sistemleri yok etme, Dosyaların üzerine yazar veya kalıcı olarak siler, PathWiper

C2 (Komuta & Kontrol), Saldırgan tarafından uzaktan kontrol sağlama, "Uzak sunucuya bağlanır, komutlar alır", Emotet

Veri Hırsızı (Data stealer), Hassas bilgileri çalma, "Dosyaları, kimlik bilgilerini veya belgeleri sızdırır", Lumma Stealer

Tuş Kaydedici (Keylogger), Kullanıcı tuş vuruşlarını kaydetme, Klavyede yazılan her şeyi yakalar, Zeus

Kripto Madenci (Cryptominer), Kripto para madenciliği için kaynakları kullanma, "Yüksek CPU kullanımı, sistemleri yavaşlatma, ağ trafiği", Coinhive

Dağıtım Formları

İkili (Binary) Kötü Amaçlı Yazılımlar

Bu tür yazılımlar .exe (Windows Executable) veya .dll (Dynamic Link Library) gibi derlenmiş dosyalar olarak dağıtılır. E-posta ekleri (fatura.pdf.exe gibi), kötü amaçlı indirmeler veya çıkarılabilir medya aracılığıyla yayılırlar. Derlendikten sonra değişmedikleri için, md5sum gibi bir sağlama toplamı (checksum) ile ad veya uzantı değişikliğinden bağımsız olarak tanımlanabilirler.

Betik Tabanlı (Script-based) Kötü Amaçlı Yazılımlar

JavaScript (.js), VBScript (.vbs), Windows batch (.bat) veya PowerShell (.ps1) gibi dillerde yazılmış betiklere dayanır. Saldırganlar için değiştirilmesi ve uyarlanması daha kolaydır. Genellikle e-posta ekleri, makro içeren Office belgeleri veya kötü amaçlı web siteleri aracılığıyla gelirler. İlk erişim için popülerdirler çünkü diske dosya yazmadan kodu doğrudan bellekte çalıştırabilirler. **Kötü Amaçlı Betiklerin Uyarı İşaretleri:**

- İnternette başka dosyalar indirmesi veya çalıştırması.
- Sistem ayarlarında değişiklik yapması veya güvenlik araçlarını devre dışı bırakması.
- Özellikle kodlanmış veya gizlenmiş içerikle, standart operasyonların parçası olmayan komutları çalıştırması.

- Beklenmedik bir şekilde PowerShell veya CMD gibi başka uygulamaları başlatması. **Örnekler:**
- **Batch (.bat) Betiği:**
- Bu betik, kötü amaçlı bir yürütülebilir dosyayı indirir ve kurbanın makinesinde çalıştırır.
- **PowerShell Betiği:**
- Bu komut, uzaktaki bir sunucudan bir betik çalıştırır ve genellikle arkasında dosya bırakmaz.